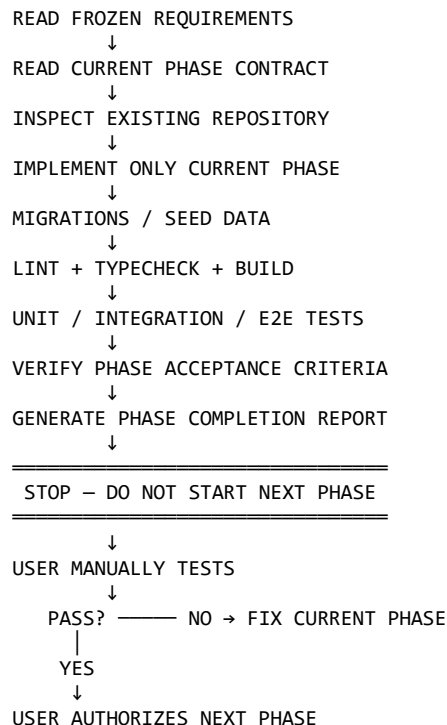


MASTER CODEX IMPLEMENTATION PLAN

1. Execution mechanism

I recommend **8 development phases**. Six would force several large subsystems together; eight gives us clean dependency boundaries without fragmenting development excessively.

The governing rule for Codex will be:



This rule applies to **every phase without exception**.

Phase 1 — Repository Foundation & Application Skeleton

Objective

Create the engineering foundation upon which every subsequent feature depends.

Dependencies

Step III–VI environment/repository preparation must have been completed.

Requirements primarily covered

FR-17, FR-29 architectural groundwork, FR-36 foundation, FR-38 foundation, FR-41 foundation, FR-43, FR-44 and FR-45 foundation.

Implementation

Repository/infrastructure: establish the pnpm/Turborepo monorepo; Next.js web application; NestJS API; worker application; shared packages; PostgreSQL/Prisma; Redis/BullMQ; object-storage abstraction; environment validation; Docker Compose local infrastructure; linting, formatting and testing.

Backend: establish NestJS modular-monolith boundaries for Auth, Users, Businesses, Applications, Marketplace, Packages, Services, Offers, Availability, Messaging, Notifications, Admin and Audit.

Frontend: establish Next.js App Router, public/application/admin route groups, global design foundation, shared UI package and responsive application shells.

Database: Prisma configuration, migration mechanism, base conventions and development seed architecture.

Operations: `/health` foundation, structured logging, environment separation and dependency-health architecture.

Security

Secrets outside source/frontend bundles, secure environment handling, API security middleware baseline, request limits and security headers.

Automated gate

Must pass clean installation, lint, typecheck, unit-test baseline, production builds, migration up/down development validation and Docker dependency startup.

Completion criteria

All applications start successfully; web communicates with API; API communicates with PostgreSQL; Redis/queue and object-storage connections work; health endpoint reports appropriate dependency state; no business functionality is prematurely invented.

Exclusions

No real registration, marketplace, packages, messaging or Admin workflows yet.

STOP FOR MANUAL USER TESTING — PHASE 1

You manually verify that the web application loads, application shells render, API responds, infrastructure starts reliably and the development environment can restart cleanly.

Phase 2 — Identity, Authentication, Authorization & Security Foundation

Objective

Establish trustworthy identity and access control **before building protected commercial functionality**.

Requirements

FR-05–FR-12, FR-17–FR-18, FR-31–FR-35, FR-38–FR-40 and FR-46.

The specification explicitly separates authentication from marketplace authorization and restricts protected B2B activity to authenticated users acting for approved businesses.

Database

Implement User, Business identity boundary, credentials/password data, sessions, verification tokens, recovery tokens, role representation, security events and audit-event foundations.

Maintain:

User ≠ Business

MVP supports one primary Business Owner per Business while preserving future multi-user extensibility.

Backend

Registration identity foundation; login/logout; email verification mechanism; mobile verification architecture; forgot/reset password; session creation/revocation/expiry; Admin/Super Admin MFA; authentication guards; RBAC; record-level authorization infrastructure; approved-business authorization policy; brute-force/rate limiting.

Frontend

Registration entry; login; logout; verification; forgot/reset password; MFA screens; session-expired handling; protected route behavior.

Security

Argon2id, secure HttpOnly cookies, production Secure/SameSite settings, CSRF protection where applicable, account-enumeration-safe recovery, rate limits, session revocation and mandatory Admin/Super Admin MFA.

Automated tests

Authentication integration tests; session tests; password recovery; expired/invalid tokens; RBAC tests; ownership tests; unauthorized/forbidden tests; MFA tests; rate-limit tests; suspended-user/session-revocation tests.

Completion criteria

Guest, Applicant, Business User, Admin and Super Admin security boundaries work; backend—not UI—enforces access; unauthorized direct API requests fail correctly.

Exclusions

No marketplace commercial functionality.

STOP FOR MANUAL USER TESTING — PHASE 2

You manually test registration/login/logout/recovery, invalid credentials, session behavior, Admin MFA and attempts to access unauthorized pages/API operations.

Phase 3 — Business Application, Verification & Admin Approval

Objective

Build the complete **Join the Network → Apply → Admin Review → Approval** workflow.

Requirements

FR-09–FR-10, FR-15–FR-16, FR-18, FR-32, FR-40, and **FR-47–FR-51**.

The frozen specification requires multi-step registration, save/continue, progress validation, documents, preview, submission and email/mobile verification.

Database

BusinessApplication, application sections/data, business type, geography, capabilities, source markets, Saudi destinations, licence/reference information, documents, configurable document requirements, application review history, Admin notes and status transitions.

Backend

Draft/save; validation; upload; preview; submit; status; correction; resubmission; Admin review; Request Information; Approve; Reject; Suspend/reactivate foundation.

Approval must create/update marketplace participation rights without conflating B2B Hyderabad approval with government accreditation.

Frontend

Professional multi-step onboarding wizard; progress/save-and-continue; upload UI; preview; application status page; correction/resubmission experience.

Admin gets Applications list and review workspace.

Background processing

Application-status event → notification job.

Notification-provider failure must **not roll back the application decision**.

Security

Applicant owns only own application; Admin review endpoints Admin-only; private documents protected; uploads validated; audit Admin decisions.

Automated tests

Lifecycle transition tests; invalid transition tests; document authorization; approval authorization; Request Information/resubmit; notification failure isolation; audit generation.

Completion criteria

Complete journey works:

- Register
- Verify
- Draft Application
- Submit
- Admin Review
- Request Information
- Correct
- Resubmit
- Approve
- Business access enabled

STOP FOR MANUAL USER TESTING — PHASE 3

This should be one of your most important manual tests. You should personally operate both Applicant and Admin sides.

Phase 4 — Business Profiles + Hajj/Umrah Commercial Inventory

Objective

Give approved businesses their marketplace identity and ability to construct real Hajj/Umrah inventory.

Requirements

FR-04, FR-13, FR-15, FR-23, FR-47 relevant data, **FR-52–FR-61**, and applicable FR-35/37.

Database

BusinessProfile; markets; locations; capabilities; languages; Package; Service; Offer; Hajj/Umrah subtype; accommodation; transport; meals; visa inclusion/status; ziyarat; inclusions/exclusions; pricing/currency; images/documents; availability rules; blackout dates; optional capacity.

Backend

Business-profile CRUD with ownership authorization.

Package/Service/Offer CRUD.

Package lifecycle:

- Draft
- Published
- Paused
- Archived

Draft deletion; published historical records archived rather than destructively removed.

Availability supports fixed departure, range, recurrence, year-round, on-request and blackout periods.

Frontend

My Business; public business profile; My Packages & Services; Create/Edit/Preview/Duplicate/Publish/Pause/Archive offering flows; availability editor; pricing editor; media/documents.

Security

Only approved owner modifies business commercial resources. Public/private information separated. Ownership checks performed backend-side.

Automated tests

CRUD, ownership, lifecycle transitions, validation, currency requirement, availability rules, geography separation, public/private profile visibility and file authorization.

Completion criteria

An approved agency can create a credible Umrah package containing the complete FR-57 data set, publish it and see it represented through its business profile.

FR-57 requires details including source/departure, destinations, travel dates, Makkah/Madinah nights, accommodation, occupancy, transport, flights where applicable, meals, visa status, ziyarat, assistance, commercial terms and availability.

STOP FOR MANUAL USER TESTING — PHASE 4

You create several realistic Hyderabad/India → Saudi Arabia Umrah packages yourself and judge whether the supplier workflow feels commercially credible.

Phase 5 — Hajj & Umrah Availability-Aware Marketplace

Objective

Implement the **central USP of B2B Hyderabad**.

Requirements

FR-01–FR-04 public discovery aspects; FR-08; FR-14–FR-15; **FR-20–FR-28**; FR-36; FR-52–FR-54; **FR-63–FR-67**.

The frozen requirement explicitly says this cannot become a static directory: marketplace discovery must answer what, where, when, for whom and under which commercial conditions.

Database/search

Create appropriate indexes and query architecture around market, source/departure, destination, dates, availability, subtype, group size, nights, accommodation, price/currency and supplier characteristics.

Backend

Server-side marketplace queries with pagination; Packages/Services/Businesses modes; structured availability matching; progressive filters; persistent search-state contract; package shortlist/comparison.

Frontend

Market selector.

Hajj & Umrah search:

Departure / Source Market
+
Travel Dates
+
Travellers / Group Size
+
Hajj / Umrah
↓
SEARCH

Results tabs:

Packages | Services | Businesses

Advanced filters, calendar availability, result cards, details, preserved search context and comparison interface.

Performance

No downloading entire datasets and filtering in browser.

Query execution must be measurable and indexed.

Automated tests

Availability matching; date boundaries; blackout dates; on-request behavior; geography; filter combinations; pagination; search-context persistence; unauthorized protected action; package comparison; query performance regression tests where practical.

Completion criteria

Changing dates genuinely changes relevant availability results.

Business physical location does not incorrectly constrain destination/source matching.

Package comparison works.

Guest discovery works while protected actions trigger authentication/approval requirements.

STOP FOR MANUAL USER TESTING — PHASE 5

This is the **primary product-quality gate**. You manually behave as a travel agency searching for different Hajj/Umrah requirements and determine whether the marketplace is genuinely useful.

Phase 6 — B2B Enquiries, Custom Package Requests & Messaging

Objective

Turn marketplace discovery into business interaction.

Requirements

FR-12, FR-14, FR-16, FR-39, FR-45, **FR-62 and FR-68–FR-71**.

Messaging must retain Business/Package/Service/Offer/Custom Request context.

Database

Conversation, participant, contextual reference, Message, attachment metadata, unread/read state, block/report data, CustomPackageRequest and appropriate event records.

Backend

Message Supplier; Enquire; custom package request; conversation list/search; send/read; attachments; unread counts; block/report; anti-spam limits.

Frontend

Messages; contextual conversation view; marketplace enquiry CTA; custom package request form; unread indicators; attachments; blocked/reported UX.

Isolation

Notifications dispatched asynchronously through BullMQ.

If email/SMS/notification provider fails:

```
Message/Request saved successfully
↓
Notification job fails
↓
Retry/log/monitor
↓
Core business action remains successful
```

Automated tests

Approved-business-only messaging; context retention; cross-business authorization; attachments; rate limits; block/report; unread state; notification retries; provider-outage isolation.

Completion criteria

Agency A discovers Agency B's package, sends an enquiry or custom requirement, Agency B receives and responds, and the conversation always retains the commercial context.

STOP FOR MANUAL USER TESTING — PHASE 6

You test using two separate approved business accounts.

Phase 7 — Complete Admin Console, Moderation & Operational Controls

Objective

Make the marketplace governable and operational.

Requirements

FR-05–FR-06, FR-18, FR-40–FR-42 and **FR-72–FR-75**.

Backend

Admin dashboard aggregation; business management; suspension/reactivation; marketplace moderation; hide/suspend listing; reports/flags; audit querying; safe system-health aggregation.

Frontend

Admin:

- Dashboard
- Applications
- Businesses
- Marketplace
- Users
- Reports
- Audit
- System Health

Security

Admin cannot impersonate suppliers or create/edit commercial material as them. Sensitive infrastructure details remain outside ordinary Admin visibility.

The frozen specification explicitly prohibits supplier impersonation and commercial actions by Admin.

Automated tests

Admin authorization; Super Admin boundaries; moderation; audit immutability; suspension; reactivation; supplier impersonation prevention; safe health information; session revocation after suspension.

Completion criteria

Admin can operate and moderate the marketplace without violating supplier ownership.

STOP FOR MANUAL USER TESTING — PHASE 7

You manually operate the Admin Console and intentionally attempt actions an Admin should **not** be able to perform.

Phase 8 — Landing Experience, Production Hardening & MVP Release Qualification

Objective

Finish the public product experience and prove the complete MVP against its production requirements.

Requirements

FR-01–FR-03 final experience; FR-16 notification completion; **FR-29–FR-45 production qualification**, plus all cross-cutting requirements and MVP Product Boundary.

Frontend

Complete blue-sky **8D Presence** landing experience; responsive/mobile optimization; reduced-motion support; Join Network and Explore Businesses routing; market selection; final dashboard polish; loading/error/empty states; accessibility and UX consistency.

The landing page's cinematic effects must support usability, mobile performance and reduced-motion preferences rather than merely add animation.

Infrastructure/operations

Production configuration; staging; backups; restore test; monitoring; Prometheus/Grafana; OpenTelemetry; structured logs; health checks; queue monitoring; security event visibility; rollback procedure.

Performance

k6 workload representing expected production behavior.

Explicit test target:

≥500 concurrent active users

with initial architecture targets already frozen around normal API p95 ≤1 second and marketplace/search p95 ≤2 seconds under the defined expected workload.

The requirement itself mandates at least 500 concurrent active users and pre-production load verification.

Security validation

Authentication abuse tests; authorization regression suite; upload security; secret exposure review; rate limits; CSRF/CORS/security headers; error-information leakage; dependency/security review.

Recovery validation

Backup → restore into controlled environment → application validation.

Full E2E

- Guest
 - Marketplace
- Applicant
 - Registration
 - Application
 - Admin Review
 - Approval
- Approved Business A
 - Profile
 - Package
 - Availability
 - Publish
- Approved Business B
 - Search
 - Filter
 - Compare
 - Enquire
 - Custom Request
 - Message
- Admin
 - Moderate
 - Audit
 - Health

Completion criteria

All FRs traceable; automated suites pass; production builds pass; load target passes; backup restore demonstrated; no Critical/High unresolved release-blocking security issue; staging E2E passes.

STOP — FINAL MANUAL MVP ACCEPTANCE TEST

Codex must not declare the application complete merely because automated tests pass.

You perform the final product acceptance.

2. FR-01 → FR-75 TRACEABILITY MATRIX

This is the control mechanism preventing requirements from disappearing during development.

FR	Requirement	Primary phase	Verification
01	Landing / 8D Presence	8	Responsive, reduced-motion + manual visual acceptance
02	Landing actions/access	5/8	E2E Guest/Join/Explore routing
03	Market/Country context	5	Persistence + search-context E2E
04	Verticals/business identity	1/4/5	Data-model + navigation tests
05	Super Admin	2/7	RBAC tests
06	Admin authority	2/7	Permission + negative tests
07	Business User/types	2/3	Data/RBAC tests
08	Guest discovery	5	Guest E2E
09	Applicant state	3	Lifecycle tests
10	Membership lifecycle	3	State-transition tests
11	Authentication vs authorization	2	Authorization integration tests
12	Protected business actions	2/4/6	Negative API tests
13	Package/Service/Offer	4	CRUD/schema tests
14	Discovery/messaging	5/6	E2E
15	Geographic separation	3/4/5	Query/data tests
16	Status notifications	3/6/8	Job/provider-isolation tests
17	Engineering access separation	1/2	Architecture/config review
18	Admin auditability	2/3/7	Audit integration tests
19	Deferred detail resolved by Set 05	3–7	Traceability review
20	Availability-aware discovery	5	Search integration/E2E
21	Calendar/date filtering	5	Availability/date tests

FR	Requirement	Primary phase	Verification
22	Vertical-specific search	5	Schema/search tests
23	Supplier availability	4/5	Availability CRUD/query tests
24	Geographic matching	5	Geographic query tests
25	Search context continuity	5	Browser E2E
26	Progressive filters	5	UI/E2E/manual UX
27	Visa result claims	5/8	Content/UI assertion
28	Deferred filter detail	5	Set-05 conformity review
29	500 concurrent users	8	k6 load test
30	99.9% objective	8	Monitoring/configuration review
31	Authentication lifecycle	2	Auth E2E/integration
32	State-aware routing	2/3	Role/state E2E
33	Secure sessions	2	Security integration tests
34	MFA	2	Admin/Super Admin MFA E2E
35	Backend authorization	2–7	Authorization regression suite
36	PostgreSQL/search	1/4/5	DB/query/index review
37	Secure files	3/4/6	Upload/access tests
38	API/secrets security	1/2/8	Security tests/review
39	Rate limiting	2/5/6/8	Abuse/rate-limit tests
40	Audit records	2/3/7	Audit tests
41	Observability/health	1/7/8	Health/metrics/log validation
42	Backups/recovery	8	Restore exercise
43	Environment separation	1/8	Configuration/deployment validation
44	Modular/horizontal backend	1/8	Architecture + multi-instance test
45	Failure isolation	3/6/8	Dependency-failure tests
46	One-owner MVP	2/3	Data/authorization tests
47	Registration information	3	Form/API/schema E2E
48	Registration flow	3	Browser E2E
49	Document requirements	3	Configuration/upload tests
50	Review/correction	3	Applicant/Admin E2E
51	Approval vs accreditation	3/4	UI/content/data validation
52	Business profile	4	CRUD/E2E
53	Geography/trust	4/5	Profile/search tests
54	Contact visibility	4/5	Guest/Business authorization tests
55	Commercial objects	4	Schema/CRUD tests
56	Hajj/Umrah subtypes	4/5	Model/filter tests
57	Umrah package details	4	Complete package E2E
58	Offering lifecycle	4	State-transition tests
59	Availability/capacity	4/5	Availability tests
60	B2B pricing	4/5	Validation/filter tests
61	Geographic separation	4/5	Data/query tests
62	Custom package request	6	Cross-business E2E
63	Business navigation	4/5/6/8	Navigation E2E/manual
64	Operational dashboard	5/6/8	Dashboard E2E/manual
65	Search/results	5	Search E2E
66	Specialized filters	5	Filter matrix tests
67	Package comparison	5	Comparison E2E
68	Messaging eligibility/context	6	Authorization/context tests
69	Messaging functions	6	Messaging E2E
70	Enquiry/abuse controls	6	E2E/rate-limit/block tests
71	Messaging isolation	6/8	Failure-injection test
72	Admin workspace	7	Admin E2E/manual
73	Application/business admin	3/7	Admin E2E
74	Marketplace moderation	7	Moderation + negative tests
75	System health	7/8	Health-view tests

3. Global Codex rules

Every phase instruction should begin with five immutable rules:

1. Read the Frozen Requirements Specification.
2. Read the approved Technology Baseline.

3. Implement ONLY the authorized phase.
4. Never reinterpret, remove or silently alter a frozen requirement.
5. STOP after phase verification and wait for manual user approval.

Codex may make **implementation-level engineering decisions** that do not change requirements, but it must flag any ambiguity that would alter product behavior instead of inventing a new requirement.

4. Phase completion report

At the end of every phase Codex should produce:

PHASE COMPLETION REPORT

Phase:
Status:

Implemented:
Files/modules created:
Database migrations:
API endpoints:
UI/routes:
Security controls:

Frozen requirements covered:
FR-XX
FR-XX
...

Tests:
Unit:
Integration:
E2E:
Security:

Lint: PASS/FAIL
Typecheck: PASS/FAIL
Tests: PASS/FAIL
Production Build: PASS/FAIL

Known limitations:
Deferred items:
Requirement deviations: NONE / EXPLAIN

MANUAL TEST INSTRUCTIONS:
1.
2.
3.
...

STOP:
Awaiting user acceptance.

If Codex reports a requirement deviation, **the phase cannot be considered complete simply because the build passes.**

5. Manual acceptance mechanism

After each phase, you will give one of three decisions:

APPROVED — phase freezes and we authorize the next phase.

CORRECTIONS REQUIRED — Codex stays within the same phase, fixes the defects, reruns tests and stops again.

REQUIREMENT CHANGE REQUIRED — development stops. We modify the Frozen Requirements through formal change control first and only then update the implementation plan.

That distinction will prevent a bug fix from accidentally becoming a product redesign.

Step-II status

I now consider the **structure of the Master Codex Implementation Plan substantially complete**: 8 dependency-ordered phases, explicit Codex boundaries, automated gates, your mandatory manual gate, and complete FR-01 → FR-75 traceability.

One important thing I have **not** done is silently freeze Step II. You asked us previously to review before freezing, and the requirements themselves require explicit change control.

Your next action is to review these 8 phases. If you approve them, we can freeze **Step II — Master Codex Implementation Mechanism**, and only then proceed to **Step III: development environment and exact dependency/version setup**.